BASELINE PROJECT PLAN

AI-Powered Cybersecurity Incident Detection and Response Management System

INSY281: System Analysis & Design | Lecturer: Mr. Jefferson Mwatati | Report prepared October 2026

Systems Analyst	Victorious Chepchirchir Korir, Bachelor of Software Engineering, University of Eastern Africa, Baraton (UEAB)
Client / Sponsor	Savanna Logistics Ltd, Nairobi (imaginary client, 120 staff, 6-person IT department). Sponsor: Chief Operating Officer. Business owner: Head of IT.
System type	Web-based Information System combining a Transaction Processing System (incident records and workflow) and a Decision Support System (rule-based and AI-assisted analysis).
Development approach	Agile (Scrum, eight 2-week sprints) with object-oriented analysis and design using UML, following the SDLC phases of planning, analysis, design, implementation and maintenance.
Budget and duration	Ksh 1,881,000 (including 10% contingency); 16 weeks, 11 January 2027 to 30 April 2027.
GitHub repository	https://github.com/victorious23-lucky/BaselineProjectPlan.git

1. Introduction

1.1 Brief Overview and Purpose

Savanna Logistics Ltd depends on digital systems for shipment tracking, billing and customer data. Security events such as repeated failed logins, phishing reports and malware alerts are currently reported by phone, email and an Excel sheet kept by IT support. This project will build a centralized web application that records incidents, analyzes authorized security logs, flags suspicious patterns with configurable rules, offers AI-assisted classification and summaries, and tracks each incident from report to resolution. AI recommendations support, and never replace, the decision of a human analyst.

1.2 Problem and Opportunity

- **Problem:** incidents are logged inconsistently, there is no priority ranking, ownership is unclear, and management cannot measure response times. The 2026 IT log shows an average of about 3 days to assign an incident (baseline to be re-measured during analysis).
- **Opportunity:** a low-cost, tailored system can cut triage time, give a full audit trail for compliance, and provide a dashboard for management decisions.

1.3 Recommended Course of Action

Build a custom MERN (MongoDB, Express.js, React, Node.js) system with a hybrid detection engine (transparent rules plus AI assistance) in 16 weeks, delivered in incremental sprints with client sign-off at each milestone (Option D in Section 2.1).

1.4 Project Scope

Scope element	Definition
Units affected	IT department (main users, 6 staff); Finance, Operations and HR (reporters of incidents); Management (dashboards and reports); all 120 staff as potential reporters.
Interaction with other systems	Accepts CSV/JSON log files exported from the company's directory and email servers; sends notifications through SMTP email; calls an AI provider API from the server only; hosted MongoDB database; one-time import of the existing Excel incident register.
Range of capabilities (in scope)	Role-based login (Administrator, Analyst, Reporter); incident reporting; validated log upload; at least 10 configurable detection rules; AI classification, severity suggestion and summary; analyst review; assignment and status tracking; dashboard; notifications; audit trail; report export.
Out of scope	Autonomous blocking of accounts or traffic, scanning of external systems, replacing a full enterprise SIEM, mobile native apps.

Scope / Major Project Activities

Activity	Description
Planning and requirements	Stakeholder interviews, current-process review, feasibility study, requirements specification (functional and non-functional).
System design	Use-case, activity, sequence and class diagrams; data-flow diagrams; MongoDB schema (6 collections); wireframes; REST API specification.
Core development	Authentication and roles, incident reporting, log upload, rule-based detection engine.
AI integration and dashboard	Structured AI analysis with output validation, analyst review workflow, dashboard, notifications and reports.
Testing and evaluation	Functional, security, usability and performance tests; precision, recall and F1 comparison of rule-only vs AI-assisted detection on labeled data.
Deployment and handover	Production deployment, user training (2 sessions), user manual, final report and presentation.

2. System Description

2.1 Alternative Solutions

Option	Description	Assessment
A. Keep current process	Email, phone calls and Excel register.	Cheapest now, but does not solve the problem: no prioritization, no audit trail, no metrics. Rejected.
B. Buy enterprise SIEM	Commercial security platform with licences.	Very capable, but licence and specialist-staff costs are too high for a 120-person firm and it is more complex than needed. Rejected.
C. Customize open-source SIEM	Adapt a free SIEM and add workflow tools.	Low licence cost, but heavy server setup and a steep learning curve for the small IT team, and it lacks a tailored incident workflow. Considered.
D. Custom MERN system (recommended)	Tailored web application with rules plus AI assistance.	Fits the company's workflow and budget, uses widely known web technologies, and can grow in later phases. Selected.

2.2 Narrative Description of the Proposed System

A staff member or an administrator submits an incident form or uploads an authorized log file. The server validates the input and stores normalized events in MongoDB. The rule engine checks each event against configured patterns. For example, 25 failed logins on one account within 2 minutes raises an alert. The alert is passed, with personal data minimized, to the AI service, which returns a validated result: suggested category (such as possible brute-force attempt), recommended severity, supporting indicators, a confidence level and suggested investigation steps. An analyst then accepts, corrects, dismisses or escalates the recommendation, and the decision is recorded. The incident moves through the statuses Open, Investigating, Resolved and Closed, with notes, assignments and notifications. Managers view dashboards of incidents by severity, category, status and response time. Every important action is written to an audit log. The React client talks to the Express REST API over HTTPS; AI keys and database credentials stay in server-side environment variables.

2.3 Deliverables

Deliverable	Description / Measurable details
Deployed web application	7 modules live on a public HTTPS URL, with 3 user roles and 6 MongoDB collections (users, securityEvents, incidents, aiAnalyses, responseActions, auditLogs).
Detection engine	At least 10 configurable rules; processes a 10,000-event log file in under 60 seconds.
AI-assisted analysis	Classification, severity, summary and investigation steps with 100% of outputs schema-validated and 100% requiring analyst review.
Dashboard and reports	At least 5 charts (severity, category, status, trend, response time); export of incident reports to PDF/CSV.
Labeled test dataset and evaluation	At least 500 labeled events; reported precision, recall, F1 and false-positive rate for rule-only vs AI-assisted detection (results reported as measured).
Test suite	Automated unit and API tests with at least 70% coverage of server code.
Documentation	SRS, UML and data-flow diagrams, user manual, final report, GitHub repository with setup instructions, defense presentation.

3. Feasibility Assessment

3.1 Economic Feasibility: Project Costs and Benefits

Cost item	Basis	Cost (Ksh)
Project manager (part-time)	16 weeks	160,000
Systems analyst	4 months at 60,000	240,000
2 full-stack MERN developers	4 months at 80,000 each	640,000
UI/UX designer	6 weeks	90,000
QA and security tester	3 months at 50,000	150,000
Development devices and test equipment	Shared, one-off	120,000
Cloud hosting, hosted MongoDB, domain and SSL	First year	60,000
AI API credits	Development and first year	90,000
User training and printed/online manuals	2 sessions	60,000
External security review	One-off penetration test	100,000
Contingency	10% of Ksh 1,710,000	171,000
TOTAL PROJECT BUDGET		**1,881,000**

Estimated benefits (assumptions to be validated during analysis): about Ksh 360,000 per year in IT staff time saved through faster triage and automatic reporting; about Ksh 420,000 per year in avoided downtime and losses through quicker response; about Ksh 120,000 per year in reduced audit and compliance preparation effort. Total about Ksh 900,000 per year. Annual running cost (hosting, AI API, maintenance) is about Ksh 150,000, giving net benefit of about Ksh 750,000 per

year. **Payback period is about 2.5 years; 5-year net present value at 12% is about Ksh 822,600**, so the project is economically feasible. Intangible benefits include better evidence for audits, consistent records and improved staff awareness.

3.2 Technical Difficulties and Mitigation

Difficulty / risk	Mitigation
AI may misclassify events or give wrong explanations	Validate structured output, show confidence, require analyst review, compare against a rule-only baseline.
Logs come in different formats; logs may carry malicious text (prompt injection)	Normalize to one schema, validate uploads, treat all log text as untrusted input before it reaches the AI.
AI service outage or cost spikes	Fall back to rule-only mode; limit requests per day; cache results.
The system itself is a target	Password hashing (bcrypt or Argon2), role-based access, HTTPS, input validation, OWASP API Top 10 checks, external security review.
Too many false positives from rules	Adjustable thresholds and rule tuning using the labeled dataset.
Team learning curve on AI integration	Early prototype in Sprint 3; knowledge sharing in weekly technical sessions.

3.3 Operational, Schedule, Legal and Contractual, and Political Feasibility

- **Operational:** the IT team already handles incidents manually, so the system matches current roles. Two training sessions and a user manual support adoption. Feasible.
- **Schedule:** 16 weeks with a 5-person team in eight 2-week sprints, with testing and buffer in Weeks 13 to 16. Feasible if scope changes are controlled.
- **Legal and contractual:** compliance with the Kenya Data Protection Act, 2019 (data minimization, security safeguards, data processing terms with the hosting and AI providers); written authorization to process company logs; contract clauses on software ownership, acceptance criteria, payment milestones, confidentiality (NDA) and support after go-live.
- **Political:** the sponsor supports the project. Some staff may fear monitoring, so access is role-based, purposes are documented and every access is audited. IT staff are reassured that the system assists them rather than replaces them.

3.4 High-Level Project Schedule and Major Milestones

Milestone	Expected completion	Description / Details
M1: Plan approved	Fri 22 Jan 2027 (Weeks 1-2)	BPP signed by sponsor; literature review and stakeholder interviews done.
M2: Requirements and design signed off	Fri 5 Feb 2027 (Weeks 3-4)	SRS, UML and data-flow diagrams, database schema, wireframes and API specification approved.
M3: Foundation ready	Fri 19 Feb 2027 (Weeks 5-6)	MERN project structure, CI on GitHub, login with 3 roles working on a test server.
M4: Reporting and detection	Fri 12 Mar 2027 (Weeks 7-9)	Incident forms, validated log upload, at least 10 rules, audit trail.
M5: AI and dashboard	Fri 2 Apr 2027 (Weeks 10-12)	AI analysis with analyst review, dashboard, notifications.
M6: Testing and evaluation	Fri 16 Apr 2027 (Weeks 13-14)	All test types done; evaluation metrics documented; defects fixed.
M7: Go-live and handover	Fri 30 Apr 2027 (Weeks 15-16)	Deployment, training, user manual, final report and presentation.

4. Management Issues

4.1 Management Concerns

- Data privacy and the risk of sending sensitive information to an external AI provider (addressed by data minimization and server-side processing).
- Reliability of AI advice and who is accountable for decisions (the analyst always decides).
- Budget overruns and scope creep (10% contingency; change control; sponsor approval for changes above 5% of budget).
- Disruption to daily work during deployment (staged rollout, parallel run with the Excel register for 2 weeks) and dependence on a few developers (documentation and code reviews).

4.2 Team Composition

Role	Responsibility
Sponsor (COO) and Head of IT	Approve budget and milestones; provide logs and user access; accept deliverables.
Project manager	Schedule, risks, budget tracking and status reports.
Systems analyst: Victorious Chepchirchir Korir	Requirements, feasibility, UML modelling, BPP, acceptance testing coordination.
2 full-stack developers	Implement React front end, Express API, MongoDB and AI integration.
UI/UX designer and QA/security tester	Wireframes and usability; test plans and security testing.

4.3 Communication Plan

Communication	Frequency	Audience and content
Written status report (1 page)	Weekly, every Friday	Sponsor, Head of IT: progress against milestones, tasks done, budget spent, risks and issues, plan for next week.
Sprint review and demo	Every 2 weeks	Stakeholders: working increment, feedback and backlog changes.
Milestone report and sign-off	At each milestone (M1-M7)	Sponsor: deliverables completed, acceptance decision.
Steering meeting	Monthly	Sponsor and management: budget, schedule, change requests.
Daily stand-up (15 minutes)	Daily	Project team: yesterday, today and blockers.

4.4 Project Standards and Procedures

- **Modelling and documentation:** UML 2.x and data-flow diagrams; REST API documented with OpenAPI; README and setup instructions in GitHub.
- **Coding and version control:** GitHub branching with pull-request review before merging; ESLint and Prettier; clear commit messages; no secrets in the repository.
- **Quality and security:** automated tests (Jest/Vitest and Supertest) with at least 70% coverage; OWASP API Security Top 10 (2023) checklist; incident lifecycle aligned with NIST SP 800-61 Rev. 3.
- **Change control and reporting:** every change request is logged, assessed for cost and schedule, and approved by the sponsor; this BPP is updated whenever scope, budget or schedule changes.